Política de Gestión de Terceros y del Círculo de Confianza

C-044 mantiene el registro de contratas en soporte papel y dominio ORGANIZATIVO. Su trazabilidad documental se mantiene en A.5.33; no acredita A.8.15 ni cobertura DIGITAL para RSC-020. La cobertura digital queda pendiente de diseño sin ampliar los sistemas del escenario.

ISO/IEC 27001:2022 — Anexo A 5.18 a 5.23, A 5.25, A 6.3, A 6.5, A 6.6, A 7.2, A 7.3, A 7.6, A 7.10, A 7.13, A 7.14, A 8.2, A 8.9, A 8.15, A 8.17, A 8.22

Código de documento	SGSI-DOC-006	**Versión**	1.7
Estado	Borrador	**Clasificación**	Interna
Propietario	Dirección General — Atalaya GP SL	**Autor**	El consultor (externo)
Fecha de emisión	12/06/2026	**Fecha de aprobación**	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4	**Registro de aprobación**	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
0.1	12/06/2026	El consultor	Emisión inicial; trata los riesgos RSC-004, RSC-005, RSC-008, RSC-009, RSC-011
1.0	03/07/2026	Comité de Seguridad Convergente	Aprobación del documento
1.1	24/07/2026	El consultor	Alta de §7 (contratas, reglas O1-O5) y §8 (visitas no contractuales, reglas N1-N3). Ver decisiones.md §13.
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Corrección de estructura: filas de trazabilidad de §7 y §8 trasladadas al Anexo A.
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	24/07/2026	El consultor	Corrección de §8 (tres reglas N1-N3, no dos) y del mapeo del Anexo A. Ver decisiones.md §13.
1.3	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.4	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	21/08/2026	El consultor	Corrección de trazabilidad del Anexo A (retirada de 8.21 en la fila MSP, alta de 7.13 en la fila de contratas, alta de 5.25 en la cabecera) y precisión de la sección 6 (naturaleza no codificada del inventario de terceros,

Versión	Fecha	Autor	Descripción del cambio
			conforme a SGSI-DOC-002 §1). Hallazgos de la verificación cruzada de agosto de 2026.
1.5	21/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.5.
1.6	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin cambios en la fecha de corte.
1.7	27/09/2026	Autor del caso	Revisión por dominios aplicables y alcance de controles. Corte 24/07/2026 conservado. Aprobación pendiente. Deltas: revisión 2026-09-27.

1. Objeto y principio rector

Regula la relación de seguridad con toda persona o entidad ajena a la plantilla que tiene acceso físico o lógico a información o instalaciones en alcance. El principio rector, establecido en la política (SGSI-DOC-003): el nivel de exigencia se determina por el acceso real, no por la naturaleza del vínculo. Un amigo de infancia con poderes notariales es, a efectos de esta política, un tercero de máximo riesgo; una gran firma de auditoría sin acceso a información Restringida, uno de riesgo bajo.

2. Clasificación de terceros por acceso real

Nivel	Definición	Terceros actuales en este nivel
T1 — Crítico	Acceso permanente a información Restringida, capacidad de administración sobre sistemas, facultades de disposición, o acceso físico no acompañado a zonas privadas.	MSP; círculo de confianza (dos personas); asesores fiscales de Dublín; agencia de comunicación, a través de la persona designada de su equipo con acceso a la cuenta del principal
T2 — Alto	Acceso recurrente a información Confidencial o acceso físico regular acompañado o a zonas comunes.	Empresa de seguridad física; personal doméstico; despacho legal español; banca privada (relación de información)
T3 — Ordinario	Acceso puntual, supervisado o a información Interna.	Contratas de mantenimiento; proveedores puntuales

3. Requisitos por nivel

Requisito	T1	T2	T3
Acuerdo/cláusulas de seguridad y confidencialidad	Contrato o acuerdo específico con anexo de seguridad completo	Cláusulas estándar en contrato	Compromiso de confidencialidad simple
Verificación previa de idoneidad	Sí, documentada, proporcional y conforme a derecho	Sí, básica (referencias y, cuando la ley lo exija, acreditación de habilitación profesional)	No requerida
Acceso lógico	Nominal, con doble factor, mínimo privilegio y registro de sesiones administrativas	Nominal si lo hay	Sin acceso lógico

Requisito	T1	T2	T3
Acceso físico	Registrado; no acompañado solo en zonas autorizadas por acuerdo	Registrado; acompañado en zonas privadas	Siempre acompañado y registrado
Derecho de auditoría/revisión	Sí, anual como mínimo	Sí, ante indicios	No
Revisión del acceso	Semestral	Anual	Al finalizar cada intervención

4. El círculo de confianza: tratamiento específico

Dos personas del entorno personal del principal disponen de acceso de nivel T1 sin marco formal alguno (SGSI-DOC-001, contexto interno). Esta política no pretende expulsarlas ni burocratizar una relación de décadas: pretende que su acceso deje de ser invisible. La regularización tiene tres piezas y una condición de método:

- Acuerdo personal de confianza (SGSI-ACU-001 y ACU-002): documento breve, en lenguaje llano, firmado con cada uno. Recoge qué acceso tienen y conservan, qué información no debe salir de la casa (con ejemplos concretos: rutinas, viajes, dispositivos de seguridad, asuntos patrimoniales), por qué canales no debe circular (mensajería personal con terceros) y a quién acudir ante cualquier contacto extraño. No es un contrato laboral ni lo aparenta.
- Revisión de facultades legales: inventario de los poderes notariales vigentes con asesoría legal, revocación de los no necesarios y sustitución de los amplios por poderes específicos con límites cuantitativos y de materia. Las cuentas de correo personales dejan de ser canal válido para actos con efectos sobre las sociedades: se les provee cuenta corporativa (objetivos O1 y O2).
- Inclusión en la concienciación (objetivo O5) con sesión propia, separada de la plantilla, impartida con la presencia del principal: la autoridad que estas dos personas reconocen es la suya, no la de un procedimiento.

Condición de método: la negociación de los acuerdos la conduce la Dirección General con el respaldo explícito del principal, comunicado por él en persona. Si el principal no antecede, esta política fracasa con el círculo, y con ella el SGSI entero: es el riesgo de implantación más alto del proyecto y se gestiona como tal.

Límite declarado de esta sección. La verificación previa de idoneidad que la sección 3 exige a todo tercero de nivel T1 no se aplica a estas dos personas, y no por descuido: someter a un screening al entrenador de toda la vida del principal y a su amigo de infancia destruiría la relación que la regularización pretende preservar, y la información que arrojaría —cuarenta años de trato personal— ya la tiene el principal. La excepción se sustituye por las tres piezas anteriores —acuerdo personal, revisión de facultades legales y concienciación— y se acepta como riesgo residual por la Dirección General. Se declara aquí porque una política que exige un control a un nivel y decide no aplicarlo a dos de sus miembros tiene que decir cuál de las dos cosas es la verdadera.

5. El MSP: requisitos reforzados

El MSP concentra la administración de los dominios físico conectado y digital (RSC-008, RSC-009). Requisitos específicos, a incorporar por anexo contractual en el plazo del objetivo O1:

- Inventario nominal de cuentas privilegiadas; doble factor obligatorio; registro de sesiones administrativas conservado 12 meses y accesible al jefe de seguridad; sincronización horaria común de todos los sistemas que generan registro —sin una referencia de tiempo única, la correlación de indicios entre el dominio físico y el digital no es defendible—; y borrado o destrucción certificada, con constancia escrita, de todo equipo o disco retirado del servicio.

- Segmentación de redes conforme al objetivo O7: los sistemas de seguridad física (CCTV, control de accesos, domótica) en red propia, sin exposición directa a internet, con acceso remoto solo mediante conexión cifrada autenticada.
- Notificación de incidentes que afecten a Atalaya en menos de 24 horas; prohibición de subcontratación del servicio sin autorización escrita.
- Supervisión: el jefe de seguridad es el propietario de la relación técnica con el MSP en los sistemas convergentes (SGSI-DOC-003, sección 6). Sin capacidad interna de verificación plena, se contrata una verificación técnica independiente anual (pentest acotado a la superficie de la residencia y la oficina), cuyo resultado alimenta el registro de riesgos.

6. Altas, cambios y bajas

Ningún tercero recibe acceso antes de la firma de su acuerdo y su alta en el inventario de terceros: la relación nominal que la Dirección General mantiene a partir de la clasificación de la sección 2, con la fecha de alta, el nivel asignado, el acceso concedido y la referencia del acuerdo o contrato que lo ampara. Este inventario es un registro operativo de la Dirección General, no un registro del SGSI codificado conforme a SGSI-DOC-002 §2: no recoge decisiones que la dirección deba aprobar, solo el estado vivo de altas, accesos y revocaciones, y se mantiene bajo el mismo principio de proporcionalidad que rige este procedimiento (SGSI-DOC-002 §1). La tabla de la sección 2 clasifica categorías; el inventario nombra personas y entidades, y es el que se recorre en las revisiones de acceso del cuadro anterior. Todo cambio de nivel de acceso exige revalidación. A la baja: revocación de accesos lógicos en el día, recuperación de llaves y credenciales físicas, y recordatorio escrito de las obligaciones de confidencialidad supervivientes. Las bajas de personal doméstico y contratas se comunican al jefe de seguridad antes de su efectividad: la ventana entre el preaviso y la salida es el momento de mayor riesgo de copia de información.

7. Trabajos, obras y contratas: planificación previa del acceso

La clasificación de la sección 2 sitúa a las contratas de mantenimiento en el nivel T3, con acompañamiento y registro. La verificación del registro de riesgos (RSC-020) demuestra que ese requisito es necesario pero insuficiente: el problema real no es cómo se acompaña a un operario, sino que nadie sabe con antelación quién va a entrar, cuándo ni a qué. Un acompañamiento no puede organizarse para una visita que se desconoce. La planificación previa es, por tanto, condición de posibilidad del control de acceso, no un trámite administrativo añadido.

Regla	Contenido
O1 — Sin planificación no hay acceso	Ningún trabajo, obra, reparación o mantenimiento accede a la residencia o a la oficina sin haber sido planificado previamente ante el jefe de seguridad, con una antelación mínima de 48 horas salvo urgencia acreditada. La urgencia no exime de la planificación: la comprime.
O2 — Lista nominal previa	El proveedor comunica por escrito y antes del acceso la relación nominal de las personas que intervendrán, con documento de identidad, y notifica cualquier sustitución. Una persona no incluida en la relación no accede, sin excepción por parte del propio proveedor.
O3 — Alcance y zona declarados	La planificación declara en qué zonas se trabajará y a qué sistemas se tocará. El acceso a zonas no declaradas requiere autorización expresa en el momento. El alcance declarado determina el nivel de acompañamiento y si procede retirar información o soportes de la zona antes de la intervención.

Regla	Contenido
O4 — Ventana horaria	Todo trabajo se ejecuta dentro de una ventana horaria acordada. La presencia de contratas fuera de esa ventana es un indicio que se anota en el cuaderno de indicios (SGSI-DOC-009), no una incidencia laboral.
O5 — Registro y cierre	Entradas y salidas se registran nominalmente y el registro se conserva y revisa mensualmente. Al finalizar la intervención se revisa el acceso conforme a la sección 6 y se comprueba que no permanecen accesos, llaves o credenciales temporales.

8. Visitas no contractuales: el límite de esta política

Esta política está construida sobre la relación contractual: clasifica terceros por el acceso que su contrato les concede y les impone requisitos proporcionales a ese acceso. Ese diseño deja fuera, por construcción, a quien accede a la residencia sin contrato alguno: los invitados de la familia. El cuasi-incidente fundacional entró exactamente por ahí. Reconocer este límite y cubrirlo explícitamente vale más que ampliar la tabla de niveles con una categoría que nadie aplicaría a un amigo de un hijo.

Las visitas no contractuales no se someten a verificación de idoneidad ni a firma de acuerdos: sería desproporcionado, inaplicable y contrario a la vida normal de una familia. Se someten a tres reglas mínimas, acordadas con la familia a través de la representante de la propiedad y no impuestas por Atalaya:

Regla	Contenido
N1 — Aviso previo	Toda visita a la residencia se comunica con antelación al servicio de seguridad, con nombre y hora aproximada. El aviso no es una autorización ni concede a Atalaya derecho de veto sobre las relaciones personales de la familia: su única función es que la presencia de esa persona esté prevista y no sea un hallazgo.
N2 — Zona social	Las visitas no verificadas permanecen en la zona social delimitada (C-046, plan PT-13; la zonificación interior de la residencia es C-025, plan PT-08), sin acceso a despachos, zonas técnicas ni áreas privadas. La delimitación se sostiene por diseño del espacio, no por vigilancia sobre los invitados.
N3 — Registro y correlación	El registro de visitas se cruza semanalmente con el cuaderno de indicios (SGSI-DOC-009, sección 5) y es una de las fuentes que alimentan la revisión semanal de correlación. Es esa revisión —y no el registro por sí solo— el control que, ejecutado, habría elevado el cuasi-incidente en la semana 4 sin depender del reconocimiento fortuito de un vehículo por parte de un miembro concreto del servicio de seguridad (reconstrucción en SGSI-REG-004, hoja «Reconstrucción 2026»).

Aceptación explícita del límite: estas reglas dependen del cumplimiento voluntario de los miembros de la familia y no son verificables por medios técnicos. Su eficacia se mide indirectamente, por la proporción de visitas registradas sobre las detectadas, y se revisa en la revisión por la dirección. Un control que descansa en la voluntad de una persona debe declararse como tal y no presentarse como una barrera.

Anexo A. Trazabilidad

Sección	Control ISO/IEC 27001:2022 (Anexo A)
2, 3 — Clasificación y requisitos	5.19, 5.20, 5.21, 5.22
4 — Círculo de confianza	5.20, 6.6, 7.2 (adaptados por contexto)
5 — MSP	5.21, 5.22, 5.23, 7.10, 7.14, 8.2, 8.9, 8.15, 8.17, 8.22
6 — Altas y bajas	5.18, 6.5
7 — Trabajos, obras y contratas	5.19, 5.20, 7.2, 7.6, 7.13, 8.15 (RSC-020)
8 — Visitas no contractuales	7.2, 7.3, 5.25, 6.3 (RSC-021)

Revisión documental 27/09/2026. La cobertura se evalúa conforme a DOC-004 v2.0: solo sobre los dominios justificados de cada escenario. El registro de contratas C-044 sigue siendo ORGANIZATIVO. RSC-020 mantiene ambos dominios por la cadena descrita y conserva la carencia digital en HD-09; RSC-021 se clasifica físico y el registro digital de visitas sigue como medida complementaria. No se añaden sistemas, accesos ni tratamientos de datos personales.